

Guía de Montaje Clase 6: Login Seguro y Sesiones

En esta clase aprenderemos a proteger nuestra aplicación. Pasaremos de un sistema abierto a uno donde los usuarios deben identificarse y donde sus contraseñas están protegidas por algoritmos de grado industrial. Necesitamos reemplazar:

```
from flask import Flask, render_template, request, redirect, url_for, jsonify
```

por este llamado actualizado:

```
from flask import Flask, render_template, request, redirect, url_for, session, flash, jsonify
```

También agregaremos

```
from werkzeug.security import generate_password_hash, check_password_hash
```

1. El Concepto de Hashing (script)

Nunca, bajo ninguna circunstancia, se debe guardar una contraseña en "texto plano" (como se escribe). Si un hacker entra a la base de datos, vería todo.

- **script:** Es el algoritmo que usaremos. Transforma la contraseña en una cadena de caracteres irreconocible. No se puede "des-enciptar", solo se puede "comparar".
- **Librería:** Usaremos `werkzeug.security` que viene incluida con Flask.

2. Gestión de Sesiones

HTTP es un protocolo "sin memoria". Cada vez que recargas la página, el servidor olvida quién eres.

- **Sesión:** Flask crea una "cookie" cifrada en el navegador del usuario. Mientras esa cookie exista, el servidor sabrá que eres tú sin pedirte la clave en cada clic.

3. Pasos para el Montaje

Paso 1: Registro con Hashing

Cuando el usuario se registra, no guardamos la clave directamente, esto lo hacemos en el

[main.py](#), en la sección de bases de datos es importante añadir esta fracción de código:

```
# Guardamos hash_clave en la DB
app.config['SECRET_KEY'] = 'mi_clave_secreta_super_segura_123'
```

De forma seguida añadimos la siguiente configuración, importante para rutas y salidas de ejecución:

```
# --- MODELO DE USUARIO ---
```

```
class Usuario(db.Model):
```

```
    id = db.Column(db.Integer, primary_key=True)
```

```
    username = db.Column(db.String(50), unique=True, nullable=False)
```

```
    # Nunca guardamos la clave real, guardamos el HASH
```

```
    password_hash = db.Column(db.String(255), nullable=False)
```

```
with app.app_context():
```

```
    db.create_all()
```

```
# --- RUTAS DE AUTENTICACIÓN ---
```

```
@app.route('/registro', methods=['GET', 'POST'])
```

```
def registro():
```

```
    if request.method == 'POST':
```

```
        usuario = request.form.get('username')
```

```
        clave = request.form.get('password')
```

```
        # Encriptamos la contraseña con scrypt
```

```
        hash_seguro = generate_password_hash(clave, method='scrypt')
```

```
        nuevo_usuario = Usuario(username=usuario, password_hash=hash_seguro)
```

```
        try:
```

```
            db.session.add(nuevo_usuario)
```

```

        db.session.commit()

        flash("Registro exitoso. Ahora puedes iniciar sesión.", "success")

        return redirect(url_for('login'))

    except:

        flash("Ese nombre de usuario ya existe.", "error")

    return render_template('registro.html')

@app.route('/login', methods=['GET', 'POST'])
def login():
    if request.method == 'POST':
        username = request.form.get('username')
        password = request.form.get('password')

        user = Usuario.query.filter_by(username=username).first()

        # Verificamos si el usuario existe Y si el hash coincide
        if user and check_password_hash(user.password_hash, password):
            # CREACIÓN DE LA SESIÓN (Recordar al usuario)
            session['user_id'] = user.id
            session['username'] = user.username
            return redirect(url_for('dashboard'))
        else:
            # Mensaje genérico por seguridad
            flash("Credenciales inválidas. Inténtalo de nuevo.", "error")

    return render_template('login.html')

# --- RUTA PROTEGIDA (DASHBOARD) ---
@app.route('/dashboard')
def dashboard():
    # Verificamos si existe la sesión
    if 'user_id' not in session:

```

```
flash("Debes iniciar sesión para acceder.", "warning")
return redirect(url_for('login'))
```

```
return render_template('dashboard.html', nombre=session['username'])
```

```
@app.route('/logout')
```

```
def logout():
```

```
    # Limpiamos la "mochila" del servidor
```

```
    session.clear()
```

```
    flash("Has cerrado sesión correctamente.", "info")
```

```
    return redirect(url_for('login'))
```

Paso 2: Crear el Registro

Crearemos un archivo llamado registro.html, con las siguientes características a continuación:

```
{% extends "base.html" %}
```

```
{% block content %}
```

```
<div class="min-h-[80vh] flex items-center justify-center">
```

```
    <div class="bg-white p-10 rounded-3xl shadow-xl border border-slate-100 w-full max-w-md">
```

```
        <div class="text-center mb-8">
```

```
            <h2 class="text-3xl font-black text-slate-900">Crear Cuenta</h2>
```

```
            <p class="text-slate-500">Únete a nuestra plataforma educativa</p>
```

```
        </div>
```

```
    <form action="/registro" method="POST" class="space-y-6">
```

```
        <div>
```

```
            <label class="block text-sm font-bold text-slate-700 mb-2">Nombre de Usuario</label>
```

```
            <input type="text" name="username" required
```

```
                class="w-full p-4 rounded-xl border-none ring-1 ring-slate-200 focus:ring-2
focus:ring-indigo-500 outline-none transition-all"
```

```
                placeholder="Ej: camilo_tutor">
```

```
        </div>
```

```

<div>
  <label class="block text-sm font-bold text-slate-700 mb-2">Contraseña</label>
  <input type="password" name="password" required
    class="w-full p-4 rounded-xl border-none ring-1 ring-slate-200 focus:ring-2
focus:ring-indigo-500 outline-none transition-all"
    placeholder=".....">
</div>
<button type="submit"
  class="w-full bg-indigo-600 text-white p-4 rounded-xl font-bold hover:bg-indigo-700
transition-colors shadow-lg shadow-indigo-200">
  Registrarse ahora
</button>
</form>

<p class="text-center mt-8 text-slate-500 text-sm">
  ¿Ya tienes cuenta? <a href="/login" class="text-indigo-600 font-bold hover:underline">Inicia sesión
aquí</a>
</p>
</div>
</div>
{% endblock %}

```

Paso 3: Verificación en el Login

Para comprobar si la clave es correcta, para ello creamos un archivo login.html:

```

{% extends "base.html" %}

{% block content %}
<div class="min-h-[80vh] flex items-center justify-center">
  <div class="bg-white p-10 rounded-3xl shadow-xl border border-slate-100 w-full max-w-md">
    <div class="text-center mb-8">
      <h2 class="text-3xl font-black text-slate-900">Bienvenido</h2>
      <p class="text-slate-500">Ingresa tus credenciales para continuar</p>

```

```

</div>

<form action="/login" method="POST" class="space-y-6">
  <div>
    <label class="block text-sm font-bold text-slate-700 mb-2">Usuario</label>
    <input type="text" name="username" required
      class="w-full p-4 rounded-xl border-none ring-1 ring-slate-200 focus:ring-2
focus:ring-indigo-500 outline-none transition-all">
  </div>
  <div>
    <label class="block text-sm font-bold text-slate-700 mb-2">Contraseña</label>
    <input type="password" name="password" required
      class="w-full p-4 rounded-xl border-none ring-1 ring-slate-200 focus:ring-2
focus:ring-indigo-500 outline-none transition-all">
  </div>
  <button type="submit"
    class="w-full bg-slate-900 text-white p-4 rounded-xl font-bold hover:bg-black
transition-colors">
    Entrar al Sistema
  </button>
</form>

<p class="text-center mt-8 text-slate-500 text-sm">
  ¿No tienes cuenta? <a href="/registro" class="text-indigo-600 font-bold
hover:underline">Regístrate gratis</a>
</p>
</div>
</div>
{% endblock %}

```

Paso 4: Proteger el Dashboard

Creemos una validación al inicio de las rutas privadas, dashboard.html:

```
{% extends "base.html" %}
```

```
{% block content %}
```

```
<div class="max-w-5xl mx-auto py-12">
```

```
  <div class="bg-white rounded-3xl shadow-sm border border-slate-100 overflow-hidden">
```

```
    <div class="bg-indigo-600 p-8 text-white flex items-center justify-between">
```

```
      <div class="flex items-center gap-6">
```

```
        <div class="w-20 h-20 bg-indigo-400 rounded-full flex items-center justify-center text-3xl font-bold border-4 border-indigo-300">
```

```
          {{ nombre[0] | upper }}
```

```
        </div>
```

```
      <div>
```

```
        <h1 class="text-3xl font-black">Panel de {{ nombre }}</h1>
```

```
        <p class="text-indigo-100">Sesión iniciada correctamente  </p>
```

```
      </div>
```

```
    </div>
```

```
    <a href="/logout" class="bg-white/10 hover:bg-white/20 px-6 py-2 rounded-xl font-bold transition-all backdrop-blur-md border border-white/20">
```

```
      Cerrar Sesión
```

```
    </a>
```

```
</div>
```

```
<div class="p-8 grid grid-cols-1 md:grid-cols-3 gap-6">
```

```
  <div class="p-6 bg-slate-50 rounded-2xl border border-slate-100 text-center">
```

```
    <p class="text-slate-400 text-xs font-black uppercase tracking-widest mb-1">Tu ID
```

único</p>

<p class="text-2xl font-mono font-bold text-slate-800">#{{ session['user_id'] }}</p>

</div>

<div class="p-6 bg-slate-50 rounded-2xl border border-slate-100 text-center">

<p class="text-slate-400 text-xs font-black uppercase tracking-widest mb-1">Estado</p>

<p class="text-2xl font-bold text-green-600">Usuario Activo</p>

</div>

<div class="p-6 bg-slate-50 rounded-2xl border border-slate-100 text-center">

<p class="text-slate-400 text-xs font-black uppercase tracking-widest mb-1">Nivel de Acceso</p>

<p class="text-2xl font-bold text-indigo-600">Administrador</p>

</div>

</div>

<div class="p-8 border-t border-slate-50">

<h3 class="text-xl font-bold text-slate-800 mb-4">Acciones Rápidas</h3>

<div class="flex gap-4">

Ir al Inicio

<button class="bg-indigo-50 text-indigo-600 px-6 py-3 rounded-xl font-bold hover:bg-indigo-100 transition">Editar Perfil</button>

</div>

</div>

</div>


```

</div>

{% endblock %}

{% with messages = get_flashed_messages(with_categories=true) %}

    {% if messages %}

        <div class="max-w-md mx-auto mt-4 space-y-2">

            {% for category, message in messages %}

                <div class="p-4 rounded-xl font-bold text-center {{ 'bg-red-100 text-red-600' if category
== 'error' else 'bg-green-100 text-green-600' }}">

                    {{ message }}

                </div>

            {% endfor %}

        </div>

    {% endif %}

{% endwith %}

```

Paso 5: Conectar el sitio

Añadimos las siguientes instrucciones a nuestro index.html para conectarlos:

```

<div class="max-w-4xl mx-auto mt-20 p-10 bg-white rounded-3xl shadow-2xl border
border-slate-100">

    <div class="flex items-center justify-between mb-8">

        <div>

            <h1 class="text-4xl font-black text-slate-900">Bienvenido, {{ nombre }} 🙌 </h1>

            <p class="text-slate-500">Este es tu panel privado protegido por sesiones.</p>

        </div>

```

```
<a href="/logout" class="bg-red-50 text-red-600 px-6 py-2 rounded-xl font-bold
hover:bg-red-100 transition">
```

```
    Cerrar Sesión
```

```
</a>
```

```
</div>
```

```
<div class="grid grid-cols-1 md:grid-cols-3 gap-6">
```

```
    <div class="p-6 bg-indigo-600 rounded-2xl text-white">
```

```
        <p class="text-indigo-200 text-sm font-bold uppercase">Estado de Seguridad</p>
```

```
        <h3 class="text-2xl font-bold mt-1">Encriptación Activa</h3>
```

```
    </div>
```

```
    <div class="p-6 bg-slate-100 rounded-2xl">
```

```
        <p class="text-slate-400 text-sm font-bold uppercase">Tu ID de Sesión</p>
```

```
        <h3 class="text-2xl font-mono font-bold mt-1 text-slate-700">#{{ session['user_id']
}}</h3>
```

```
    </div>
```

```
    <div class="p-6 bg-slate-100 rounded-2xl">
```

```
        <p class="text-slate-400 text-sm font-bold uppercase">Acceso</p>
```

```
        <h3 class="text-2xl font-bold mt-1 text-slate-700">Restringido</h3>
```

```
    </div>
```

```
</div>
```

```
</div>
```

Checklist de Seguridad

- **Mensajes Genéricos:** No digas "El usuario no existe". Di "Usuario o contraseña incorrectos". Así no das pistas a los atacantes.
- **Secret Key:** Flask necesita una `app.secret_key` muy fuerte para cifrar las sesiones. ¡Nunca la compartas!
- **Cerrar Sesión:** Siempre ofrece un botón de logout que haga `session.clear()`.